Phishing

Grundlagenpraktikum zur IT-Sicherheit (WiSe 2023/2024)

Lehrstuhl für Netz- und Datensicherheit
Ruhr-Universität Bochum

Nico S**** Sabri Öztürk

1. Mai 2026

Zusammenfassung

In diesem Versuch werden verschiedene Arten des Phishing erkundet und erklärt. Dabei werden verschiedene Tools genutzt, um zu veranschaulichen wie Angreifer das Phishing ausnutzen können, um an persönliche Daten, wie Nutzernamen und Passwörter zu kommen. Weiterhin wird eine Trainingsmethode zur Aufklärung und Erkennung von Phishingmails erläutert und ob die verschiedenen Konzepte nur positive oder auch negative Auswirkungen haben können.

Inhaltsverzeichnis

1 Einleitung **1**

1.1 Glossar 1

2 Aufbau **2**

3 Durchführung **3**

3.1 Anschauen der E-Mail 3

3.2 GoPhish 6

3.3 Spamassassin und DMARC 13

3.4 Phishing-Email 15

3.5 E-Mailsignaturen 17

3.6 Anti-Phishing Training 19

4 Zusammenfassung und Fazit **21**

5 LLM **22**

1 Einleitung

Seit vielen Jahren werden E-Mails für verschiedenste Zwecke genutzt. Über sie kann kommuniziert werden um mit Freunden in Kontakt zu bleiben, Bewerbungen für einen neuen Job zu versenden oder oft geschäftliche Unterhaltungen zu führen. Aber auch Werbefirmen und sogar Personen mit schlechten Absichten senden Tagtäglich E-Mails durch das Internet.

Konzerne können durch das Senden von E-Mails schneller mehr Menschen erreichen, die so Werbung von den verschiedensten Unternehmen erhalten. Wenn eine Person immer und immer wieder unerwünschte E-Mails von dem gleichen Sender empfängt, wird oft von *Spam* gesprochen. In Spam-E-Mails sind oft Links zu verschiedenen Internetseiten eingebaut um dort Produkte zu kaufen und dies ist auch erst einmal nicht Schädlich. Doch werden Spam- oder auch normaler aussehende E-Mails von Personen mit schlechten Absichten genutzt.

Die Angreifer nutzen E-Mails aus um Malware zu verbreiten oder persönliche Informationen zu stehlen. Diese Art Angriff nennt sich *Phishing* und gehört zur Gruppe der *Social Engeneering* Angriffe. Der Bereich Phishing teilt sich in allgemeines *Phishing* und sogenanntes *Spear-Phishing* auf.

Bei allgemeinem Phishing werden E-Mails an so viele Menschen wie möglich gesendet. Der Inhalt ist dabei nicht personalisiert und der Zweck ist meist durch falsche Versprechungen an das Geld der Opfer zu gelangen. E-Mails die als Spear-Phishing-E-Mails genutzt werden sollen, sind hingegen immer einem bestimmten Szenario oder sogar einer einzelnen Person angepasst. Beispielsweise wird in einer E-Mail geschrieben, dass ein Passwort zu einer bestimmten Webseite geändert werden müsse. Beigefügt ist dann ein Link, der zu einer gefälschten Login-Seite der jeweiligen Webseite passt. Wenn dort das Opfer die Login-Daten einträgt werden diese an den Angreifer gesendet und das Opfer auf die echte Webseite weitergeleitet um weniger aufsehen zu erregen. Das Opfer soll denken, dass die Daten falsch eingegeben wurden oder das Internet nicht richtig funktioniert hat.

Diese Angriffe können, richtig ausgeführt, sehr wirksam sein. Um besser mit potentiellen Phishing-E-Mails umgehen zu können, soll in diesem Versuch mit Phishing-E-Mails gearbeitet werden. So soll mit wenig Informationen erkannt werden, ob eine E-Mail authentisch oder gefälscht ist, woran dies zu erkennen ist und später auch selber Phishing-Mails zu konstruieren. Damit dabei niemand zu Schaden kommt wird ein *Scope* festgelegt, dass den Rahmen der Angriffe klar definiert.

1.1 Glossar

Phishing Angriff der durch E-Mails, SMS oder Anrufe die persönliche Daten abgreifen oder Malware verteillen soll

Spear-Phishing Phishing, dass auf eine einzelne Person abzielt

Scope Rahmen für Angriffe vertraglich festgehalten.

2 Aufbau

Die folgenden Versuche wurden im Netzlabor ID 2/168 unternommen.
Wir führen den Versuch zu zweit als Gruppe 43 am PC mit der IP-Adresse 192.168.1.42 durch.
Das Betriebssystem ist ein Ubuntu 22.04 LTS.

Es wurden verschiedene Programme und Befehle genutzt. Diese sind:

Software	**Version**
claws mail	4.0.0
unzip	6.00
gophish	0.12.1
firefox	103.0.1

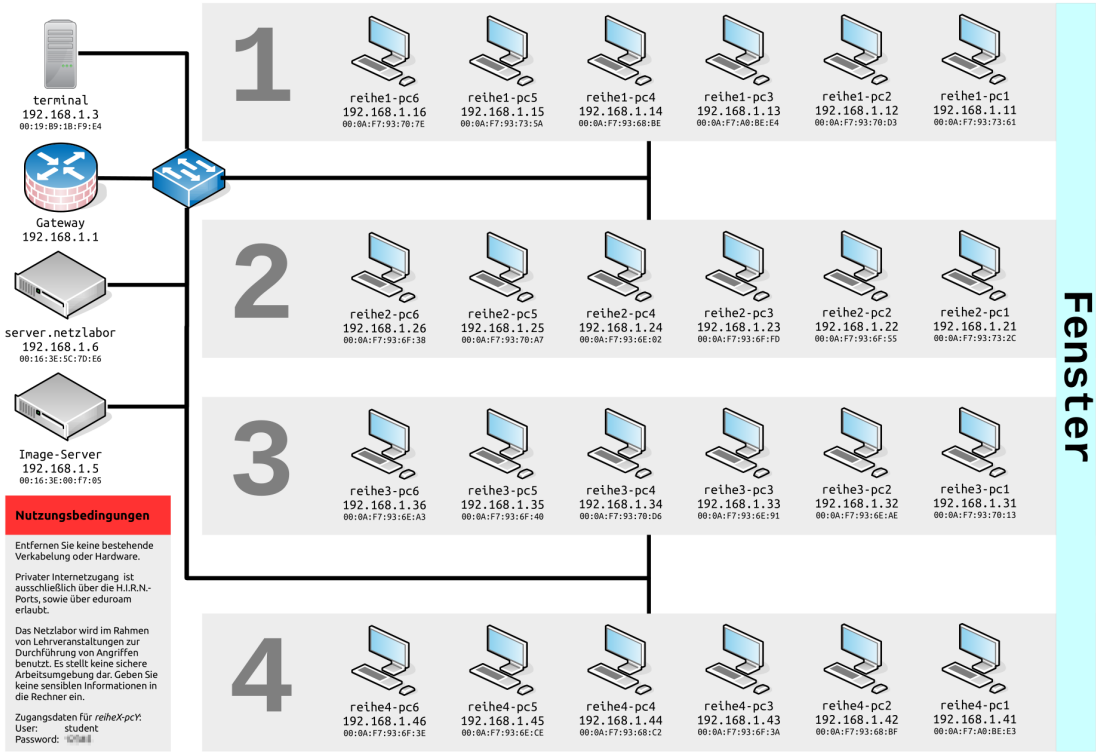


Abbildung 1: Netzplan Raum ID 2/168, Stand 01.05.2017

Die Aufgabenstellung [3] wurde bereitgestellt übe die Veranstaltungsseite [2]

3 Durchführung

Im Folgenden werden die einzelnen Aufgaben durchgeführt, erläutert und das Ergebnis präsentiert.

3.1 Anschauen der E-Mail

Bei E-Mails von unbekannten Absendern kann es wichtig sein zu wissen ob die E-Mail authentisch ist oder es sich um einen Phishing-Versuch handelt. Bei allgemeinem Phishing sind oft Grammatikfehler in den Nachrichten enthalten. Bei Spear-Phishing ist es oft so, dass die Nachricht sogar Personalisiert ist und meist einen Link zu einer Internetseite beinhaltet, die von vielen Personen besucht wird. Hierbei ist jedoch zu beachten, dass die Internetseite meist nur so aussieht wie die echte Seite, eigentlich aber von einem Angreifer kontrolliert wird, um persönliche Daten des Empfängers abzugreifen.

In dem E-Mail-Programm *Claws-Mail* auf dem zur Verfügung gestellten Computer und Account sind zwei E-Mails im Postfach enthalten. Um auch den html-Text in der E-Mail korrekt zu laden muss vor dem Betrachten der Nachrichten zuerst ein Plugin installiert werden. In *Claws-Mail* gibt es das Plugin *litehtmlviewer*, welches das Rendern von html-Inhalten ermöglicht. In Abbildung 2 sind die aktiven Plugins, in diesem Fall lediglich das Plugin *LiteHTML-Betrachter*, zu sehen.

Nun wird der Inhalt der E-Mails korrekt angezeigt. Beim ersten Betrachten beider E-Mails gibt es keine Unstimmigkeiten. Es sind keine Rechtschreibfehler vorhanden und beide E-Mails sind vom gleichen Absender, sowie an die gleiche Person adressiert und auch der Inhalt ist nahezu identisch. Auffällig ist, das ein Link zu einer Internetseite weiterleitet. Da der Link direkt angezeigt wird kann auf den ersten Blick nicht erkannt werden, auf welche Internetseite dieser weiterleitet. Jedoch wird, wenn die Maus über den Link geht, im unteren linken Rand des Browserfensters die Zieladresse angezeigt.

Die Adresse *https://www.facebook.com/settings?tab=account&section=password* wird in der ersten E-Mail angezeigt (siehe Abb. 3) also eine authentische Internetseite die auf Einstellungen in einem Facebook-Konto weiterleitet. In der zweiten E-Mail unterscheidet sich die Adresse jedoch von der ersten. Hier ist die Adresse *http://0.0.0.0:80?rid=8k1QIPZ* (siehe Abb. 4) also scheinbar keine authentische Seite von Facebook. Es lässt sich also vermuten, das diese E-Mail eine Phishing-E-Mail ist und Nutzerdaten von Facebook abgreifen soll, wenn jemand diesen Link zum einloggen nutzt.

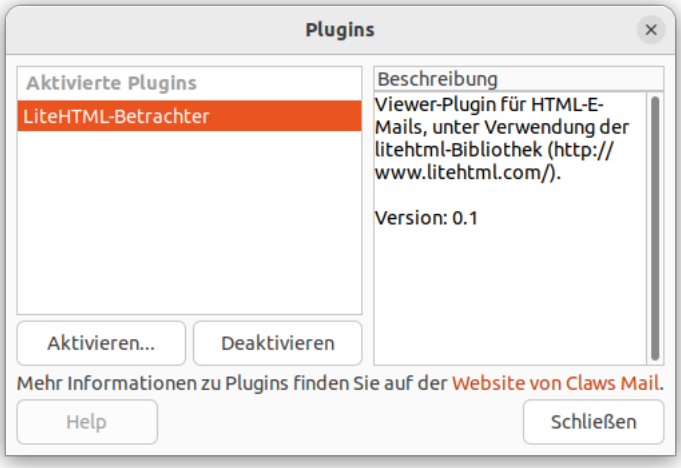


Abbildung 2: LiteHTML-Betrachter Installation

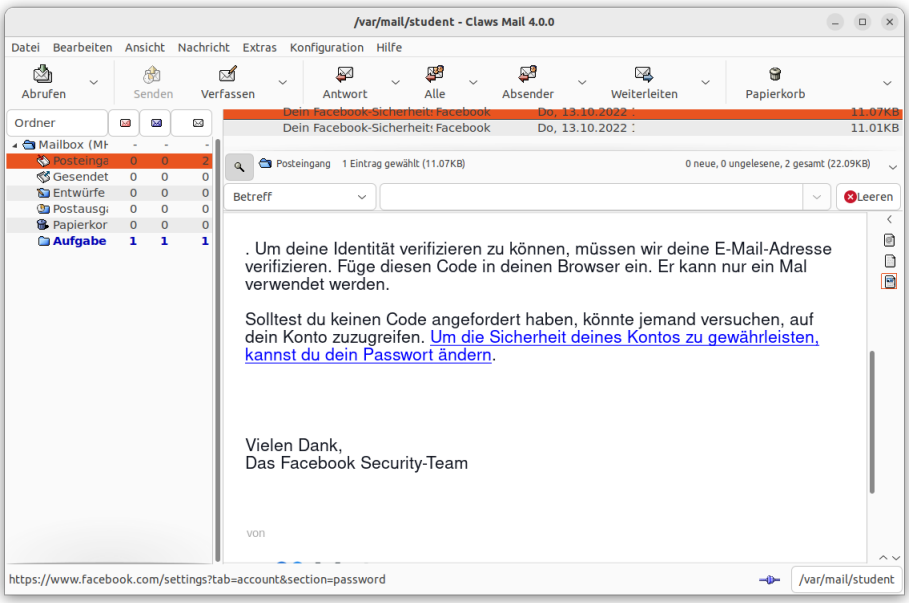


Abbildung 3: Auszug erste E-Mail, authentisch

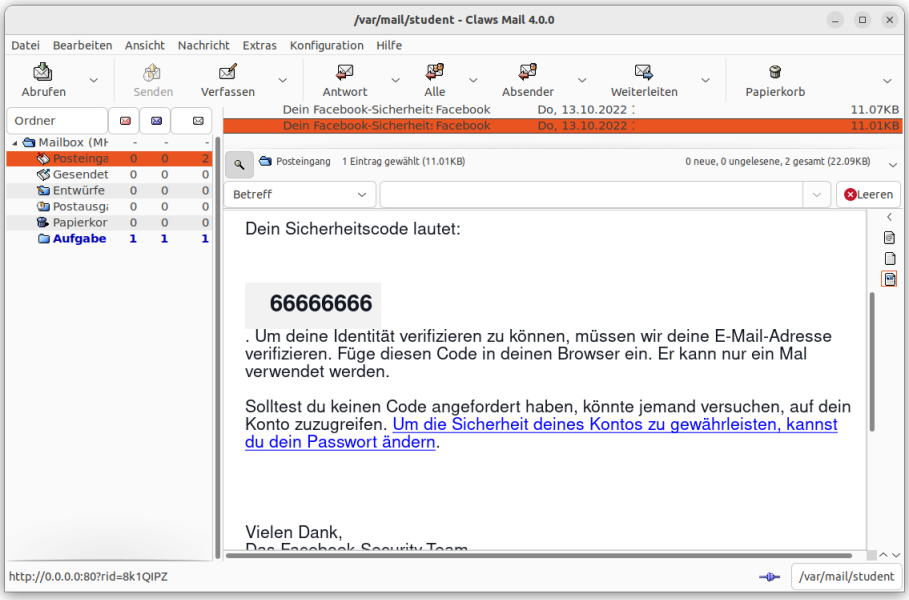


Abbildung 4: Auszug zweite E-Mail, Phishing

3.2 GoPhish

Um Phishing-E-Mails besser zu verstehen kann es helfen, selber eine solche E-Mail zu erstellen. Dadurch kann eine tiefere Einsicht in Phishing und die Konzepte die dort hinter stehen gewonnen werden. Phishing-E-Mails müssen heutzutage nicht mehr einzeln per Hand verfasst und beobachtet werden, denn auch dafür gibt es Tools und Programme. Eines dieser Programme ist *GoPhish*, welches im folgenden genutzt wird.

Um *GoPhish* nutzen zu können muss dieses ersteinmal installiert werden. Dazu ist eine ZIP-Datei mit dem Namen *gophish-v0.12.1-linux-64bit.zip* gegeben, welche entpackt werden muss. Dies geschieht über den Befehl *unzip* gefolgt von dem Dateinamen.

```
student@Reihe4-PC2:~$ cd Praktikum/Phishing/
student@Reihe4-PC2:~/Praktikum/Phishing$ ls
gophish-v0.12.1-linux-64bit.zip
student@Reihe4-PC2:~/Praktikum/Phishing$ unzip gophish-v0.12.1-linux-64bit.zip
[...]
student@Reihe4-PC2:~/Praktikum/Phishing$ ls
config.json  gophish                          LICENSE    static     VERSION
db           gophish-v0.12.1-linux-64bit.zip  README.md  templates
```

Nachdem die Dateien entpackt wurden können sie im aktuellen Verzeichnis gesehen werden. Die Datei mit dem Namen *gophish* ist das Hauptprogramm. Damit dieses gestartet werden kann müssen zuerst noch die Ausführberechtigungen gesetzt werden. Dies kann über den Befehl *chmod* erreicht werden. Danach kann die Datei ausgeführt werden.

```
student@Reihe4-PC2:~/Praktikum/Phishing$ chmod u+x gophish
student@Reihe4-PC2:~/Praktikum/Phishing$ sudo ./gophish
[sudo] Passwort für student:
[...]
time="2024-01-17T09:36:47+01:00" level=info msg="Please login with the username admin
    and the password 185bf5804b81dd2c"
time="2024-01-17T09:36:47+01:00" level=info msg="Starting IMAP monitor manager"
time="2024-01-17T09:36:47+01:00" level=info msg="Creating new self-signed certificates
    for administration interface"
time="2024-01-17T09:36:47+01:00" level=info msg="Background Worker Started Successfully
    - Waiting for Campaigns"
time="2024-01-17T09:36:47+01:00" level=info msg="Starting phishing server at http
    ://0.0.0.0:80"
time="2024-01-17T09:36:47+01:00" level=info msg="Starting new IMAP monitor for user
    admin"
time="2024-01-17T09:36:47+01:00" level=info msg="TLS Certificate Generation complete"
time="2024-01-17T09:36:47+01:00" level=info msg="Starting admin server at https
    ://127.0.0.1:3333"
```

Das Programm hat nun automatisch einige Konfigurationen durchgeführt und verschiedene Webserver gestartet. Unter der Adresse *https://127.0.0.1:3333* läuft ein admin Server. Die Anmeldedaten sind zu beginn der Konfiguration ausgegeben worden. Der Nutzername ist *admin* mit dem Passwort *185bf5804b81dd2c*. Auf diesem können Einstellungen für die Phishing-Angriffe getroffen werden. Der eigentliche Phishing-Server der Nutzerdaten abgreifen soll ist unter der Adresse *http://0.0.0.0:80* erreichbar.

Nun sollen verschiedene Einstellungen getroffen werden. Dazu wird Firefox als Browser geöffnet und die Adresse des admin Servers wird aufgerufen. Bei dem Versuch die Seite zu besuchen wird ein Fehler angezeigt, dieser kann jedoch ignoriert werden. Als nächstes müssen die Anmeldedaten angegeben werden und das Passwort geändert werden. Sobald dies geschehen ist, wird die Startseite, das Dashboard, angezeigt(siehe Abb. 5). Nun wird zuerst ein *Sendig-Profile* eingerichtet. Da die erste, authentische, E-Mail aus dem *Claws-Mail* Postfach nachgemacht werden soll, kann diese für viele Informationen als Vorlage dienen. So kann der gesamte *SMTP From Header* kopiert und in das *Sending-Profile* eingefügt werden. In dem Feld *Host* wird der im *Scope* gegebene E-Mail-Server *localhost:25* eingegeben. Über diesen werden die E-Mails verschickt, die im weiteren erstellt

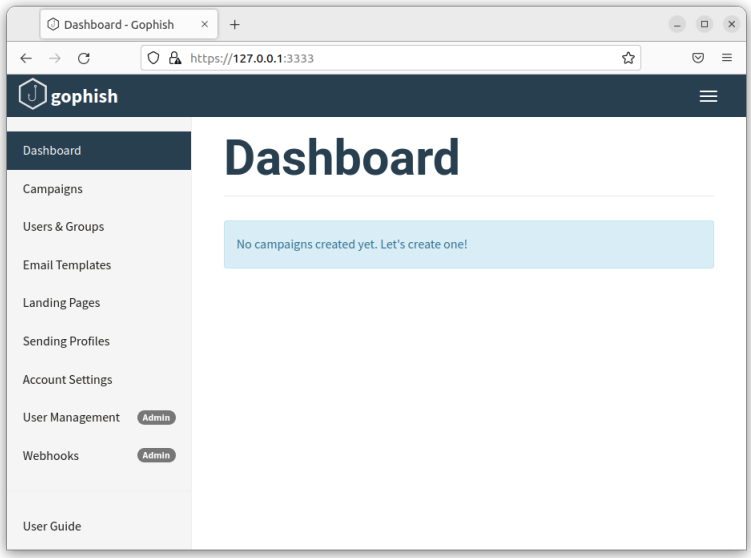


Abbildung 5: Dashboard von GoPhish

werden. Der Name dient lediglich dazu, das Profile von anderen unterscheiden zu können. Hier wurde der Name *Egal* gewählt. Die restlichen Felder müssen nicht ausgefüllt werden, also können diese so belassen werden. Die getroffenen Einstellungen können in Abbildung 6 eingesehen werden. Um zu testen ob die Einstellungen gültig sind, kann eine Test-E-Mail gesendet werden. Dazu wird die Funktion *Send Test E-Mail* genutzt. Da eine neue E-Mail im Postfach eingegangen ist, sind die Einstellungen gültig(siehe Abb. 7).

Nun muss ein Template für die E-Mails entworfen werden. Dieses kann unter dem Punkt *Email Templates* erstellt werden. Auch hier kann ein beliebiger Name gewählt werden. Über die *import* Funktion kann eine echte E-Mail als Vorlage kopiert werden. Der Inhalt der authentischen E-Mail kann in *Claws-Mail* als html-code angezeigt werden. Dann kann die E-Mail kopiert und in *GoPhish* eingefügt werden(siehe Abb. 8).

Als nächstes muss eine Landingpage gestalltet werden. Die Landingpage ist die Internetseite, die angezeigt wird, wenn auf den Link in der E-Mail geklickt wird. Sie sollte also angepasst an die E-Mail sein. Da eine E-Mail von Facebook nachgemacht wird, ist es nur Sinnvoll auch die Facebook Startseite als Vorbild für die Landingpage zu nehmen. Um diese zu kopieren kann die Funktion *Import Site* genutzt werden. Hier wird der Link der Startseite *https://www.facebook.com* eingetragen. Zudem müssen die Funktionen *Capture Submitted Data* und *Capture Passwords* eingeschaltet werden, damit die gesendeten Daten und Passwörter mit geschnitten werden. Weiter muss eine in dem Feld *Redirect To* eine weitere Internetadresse eingegeben werden. Auf diese leitet *GoPhish* Personen weiter, die Anmeldedaten auf der Landingpage eingegeben haben, damit weniger Aufsehen erregt wird. Die Seite ist eine echte Seite von Facebook, die im Kontext eines falsch eingegebenen Passworts Sinn ergibt. Hier wird die Adresse *https://www.facebook.com/login* genutzt. Zuletzt muss aus dem Sourcecode der Landingpage ein Script entfernt werden, dass verhindern soll, die Seite als Landingpage für Phishing-Angriffe zu nutzen. Das Script beginnt circa bei der Hälfte des Sourcecodes mit dem Tag *<script>* und endet mit dem *</script>* Tag. Ein Ausschnitt der Einstellungen kann in Abbildung 9 gesehen werden.

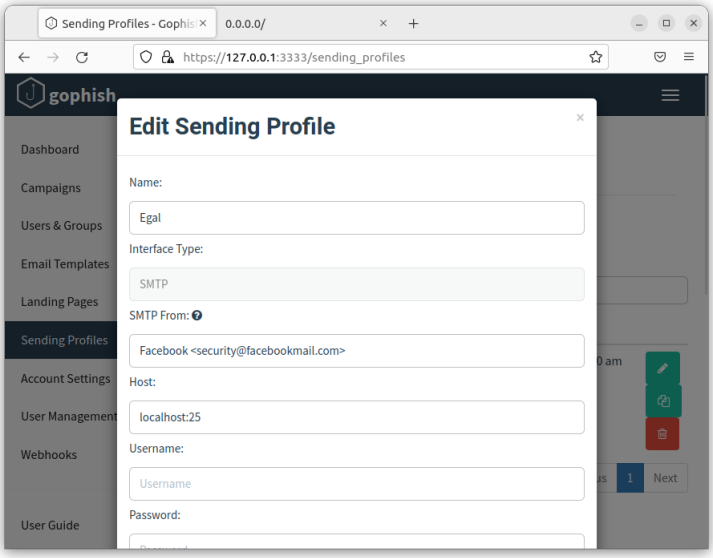


Abbildung 6: Sending Profiles in GoPhish

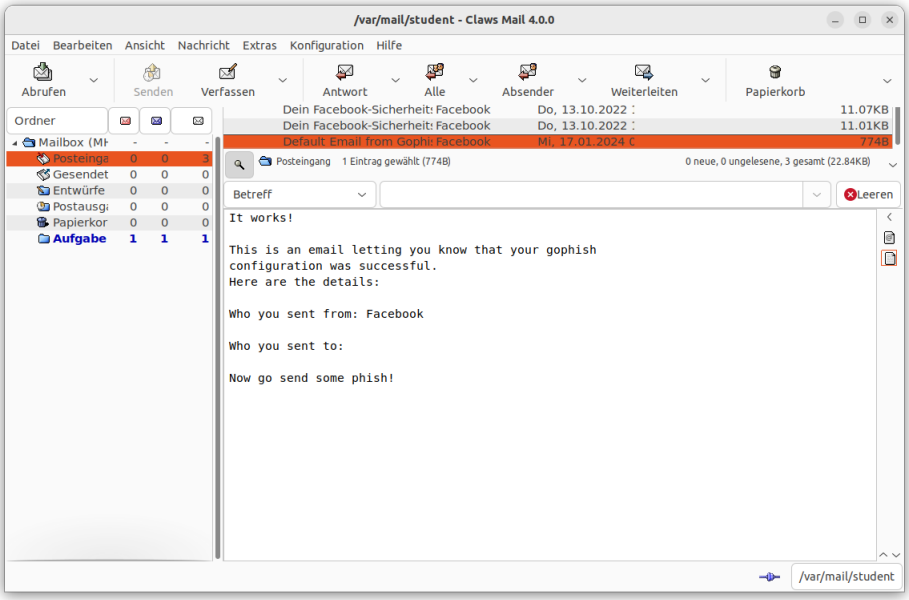


Abbildung 7: Empfangene Test-E-Mail von GoPhish

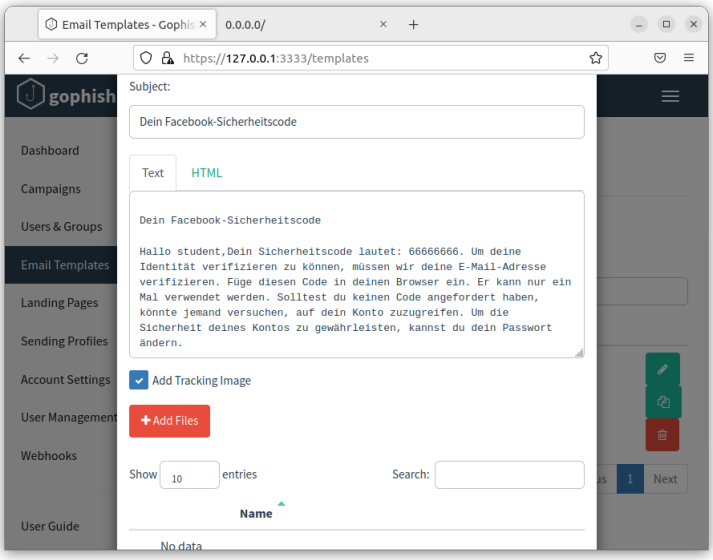


Abbildung 8: Template in GoPhish

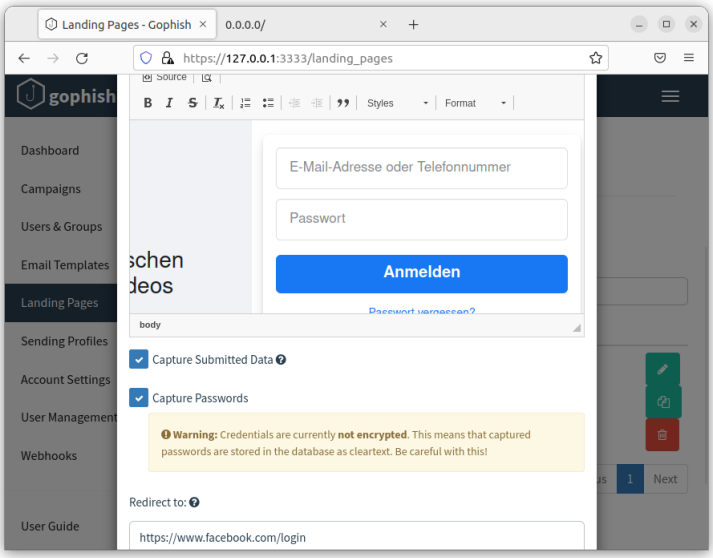


Abbildung 9: Landingpage in GoPhish

Damit die Phishing-E-Mails an Personen versandet werden müssen E-Mails hinterlegt werden. Unter *Users & Groups* können Nutzer und Gruppe erstellt werden, die später E-Mails erhalten sollen. Dort wird die im *Scope* festgelegte E-Mail-Adresse *student@localhost* eingetragen. Ein Name kann dabei helfen, die E-Mail-Adressen besser zuordnen zu können, da hier nur eine einzelne Adresse genutzt wird, muss der Name nicht aussagekräftig sein. Hier wurde der Name *Egal* verwendet. Ein Ausschnitt der Einstllungen kann in Abbildung 10 gesehen werden. Zuletzt kann die E-Mail-Kampagne gestartet werden. Unter dem Punkt *Campaigns* können dabei die vorher erstellen Templates, Landingpage, Profile und die Gruppen angegeben werden. Auch muss der Startzeitpunkt der Kampagne und die URL des Phishingservers eingetragen werden(siehe Abb. 11). Die URL steht in der Ausgabe der Konfiguration in der Konsole. Über die Funktion *Launch Campaign* wird die Kampagne nun gestartet und die präparierten E-Mails und die angegebenen E-Mail-Adressen gesendet. In *Claws-Mail* im Posteingang ist nun eine neue E-Mail erschienen. Diese sieht aus, als käme sie von Facebook, hat aber den präparierten Link, der auf die Phishing-Seite weiterleitet, eingebaut. Wenn dieser Link nun angeklickt und auf der Internetseite Logindaten eingegeben werden, werden diese an *GoPhish* zurück gesendet und das Opfer auf eine authentische Seite weitergeleitet. Für diesen Versuch wird die E-Mail *student@localhost* mit dem Passwort *12345* angegeben. In *GoPhish* können die Ergebnisse der Kampagne eingesehen werden(siehe Abb. 12). Hier ist zu sehen, dass eine E-Mail gesendet, eine geöffnet, ein Link angeklickt, einmal Daten verdendet und kein E-Mail gemeldet wurde. Dies sind auch die Ergebnisse, die erwartet wurden, da nur eine E-Mail versendet und diese nicht gemeldet wurde. Mit der Funktion *Export CSV* können die Daten herunter geladen werden. In der Datei *Egal - Events.csv* sind die verschiedenen Events enthalten. Das letzte Event *Submitted Data* enthält die E-Mail und das Passwort das eingegeben wurde.

```
1,student@localhost,2024-01-17T09:14:08.403148493Z,Submitted Data,"{[...],""email"":[""
    student@localhost""],[...],""password"":[""12345""],[...]}"
```

Auf eine gleiche oder sehr ähnliche Art und Weise können Angreifer E-Mails verschicken um echten Menschen Daten zu verschiedenen Accounts zu entlocken. Dies kann schwerwiegende Folgen wie Identitätsdiebstahl haben. Aus Gründen wie diesem ist darauf zu achten, dass keine Phishing-E-Mails versendet werden, da schon der Versuch von Phishig, egal ob zum Spaß oder ernst, strafbar ist.

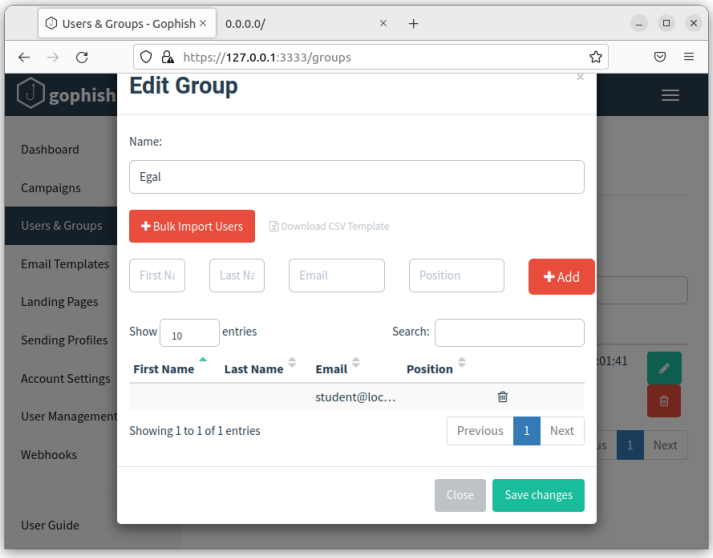


Abbildung 10: Gruppe mit eingetragener E-Mail-Adresse in GoPhish

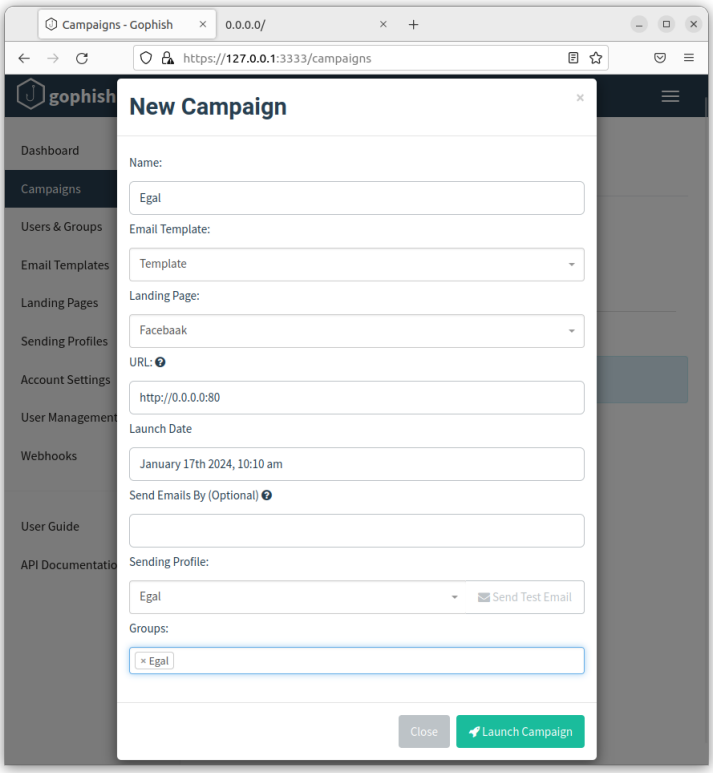


Abbildung 11: Kampagnen Einstellungen in GoPhish

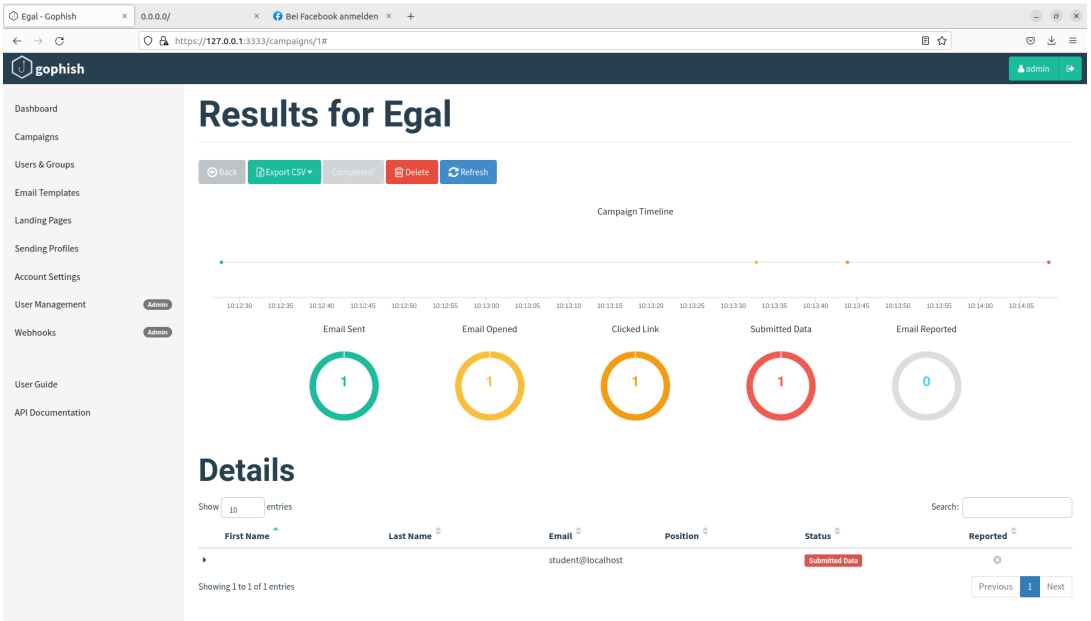


Abbildung 12: Ergebnisse der Kampagne in GoPhish

3.3 Spamassassin und DMARC

Damit Menschen vor Phishing-E-Mails geschützt werden gibt es Spam Filter. Diese untersuchen meist die Header der empfangenen E-Mails. In Headern stehen bestimmte Daten über den Absender oder auch welche Protokolle genutzt wurden um die E-Mail zu signieren und zu senden. Die Phishing-E-Mail die zuvor versendet wurde, wird leicht von einem Spam Filter erkannt. Um zu verstehen warum, können die Header genauer betrachtet werden.

In Abbildung 13 kann der Spam-Report der E-Mail gesehen werden. Als Gründe, warum die E-Mail als Spam gekennzeichnet ist, werden 12 Punkte angegeben. Jedem dieser Punkte wird ein Wert zu gewiesen, der darauf hindeutet, wie sehr dieser Punkt auf Spam hindeutet. Wenn die Summe aller Werte einen bestimmten Wert überschreitet, wird die E-Mail als Spam gekennzeichnet.

Der erste Punkt im Report ist die Bayes'sche Bewertung, ein statistisches Lernverfahren, welches die Spam-Sicherheit erhöhen soll [1]. Der zweite Punkt ist mit einem hohen Wert versehen, also sehr relevant. Es handelt sich um die Warnung, dass der Sender nicht mit den SPF Aufzeichnungen übereinstimmt. SPF steht für *Sender Policy Framework* und soll das spoofen, also nachahmen, von E-Mail-Adressen verhindert. Das dieser Punkt aufgelistet ist, ergibt Sinn, da die genutzte E-Mail-Adresse zu Facebook gehört und von uns gespoofed wurde. Der nächste Punkt hat den dritt höchsten Wert zugewiesen bekommen, also sollte auch dieser Punkt wichtig sein. Es handelt sich um den Hinweis, dass die Domain die genutzt wurde um die E-Mail zu signieren jede E-Mail signiert und diese Mail so nicht als vertrauenswürdig einzustufen ist.

Das Verfahren welches die E-Mails signiert nennt sich DKIM, DomainKeys Indentified Mail, und signiert E-Mails mit einem privaten Schlüssel. Die Signatur kann über den öffentlichen Schlüssel bestätigt werden, dieser wird aus dem DNS-Record genommen und kann so prüfen, ob die E-Mail von dem jeweiligen Absender stammt.

Der nächste Interessante Punkt ist Punkt fünf. Hier wurde erkannt, dass die eingebettete URL eine numerische IP-Adresse enthält. Dies ist oft ein Zeichen dafür, dass auf nicht vertrauenswürdige Internetseite weitergeleitet werden soll. Der wichtigste Punkt ist jedoch Punkt zehn. Dieser hat mit zehn Punkten den höchsten Wert und sagt aus, dass die Überprüfung von DMARC, Domain-based Message Authentication Reporting Conformance, fehlgeschlagen ist. DMARC verbindet SPF und DKIM in einem einfach zu nutzenden Struktur und ist der Standard für Authentifizierung im E-Mail-Verkehr.

Die Restlichen Punkte sind nicht oder nur sehr wenig gewichtet, so haben diesen nicht viel Aussagekraft ob die E-Mail eine Spam Nachricht ist oder nicht. Doch die angesprochenen Punkte reichen aus um deutlich zu Zeigen, dass es sich um eine Spam-E-Mail handelt.

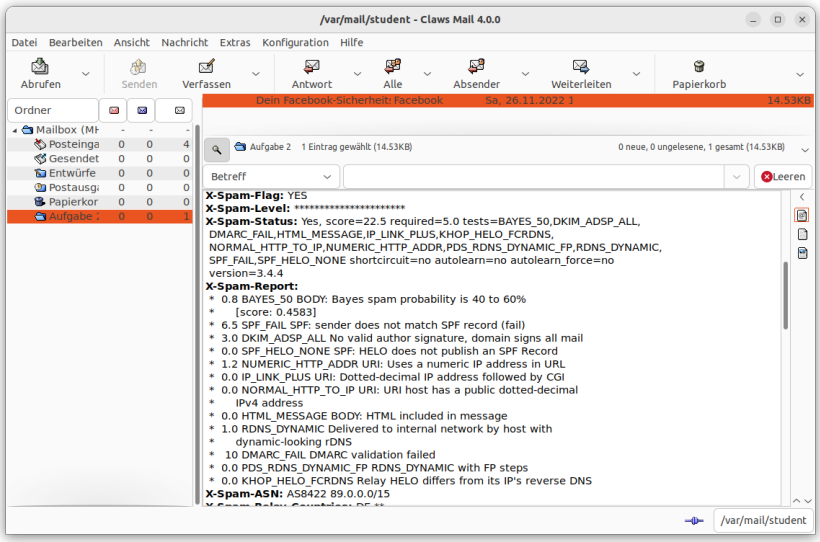


Abbildung 13: Auszug der Header der Phishing-E-Mail

3.4 Phishing-Email

Das Designen von Phishing-E-Mails kann dabei helfen diese selber zu erkennen. Zu diesem Zweck soll eine so eine E-Mail nun erstellt werden. Das Ziel der E-Mail ist es, E-Mail-Adressen mit Passwörtern und Ausweisnummern abzugreifen.

Um möglichst viele Leute mit einem Thema anzusprechen haben wir uns die 200€ Pauschale als Vorbild genommen. Das Geld soll, wie auch in der Vergangenheit geschehen, vom Staat ausgezahlt werden, damit handelt es sich um das *Principle of Authority*, welches genutzt wird um das Vertrauen der Empfänger zu gewinnen.

Es soll eine E-Mail-Kampagne gestartet werden die verbreitet, dass jeder Bürger das Recht auf 200€ hat und sich lediglich per E-Mail und mit der Ausweisnummer anmelden muss. Da das Konzept simpel erscheint, werden vermutlich mehr Leute versuchen das Geld zu beantragen.

Die E-Mail-Adressen die für die Kampagne benötigt werden können im Internet gekauft werden. Dort gibt es Sammlungen von E-Mail-Adresse für Werbungen, die von uns ausgenutzt werden können.

Die Landingpage sollte der Internetseite der Bundesregierung nachempfunden sein. Auch wenn es stark auf einen Phishing-Versuch hindeuten kann, sollten auf der Webseite drei Felder für Informationen vorhanden sein: eines für die Ausweisnummer, eines für die E-Mail-Adresse und eines für das Passwort. Sobald die Felder ausgefüllt und ein Knopf zur Bestätigung geklickt wurde, findet das Senden der Informationen und die Weiterleitung statt.

Die Weiterleitung sollte entweder zu einem E-Mail-Service oder zur offiziellen Webseite der Bundesregierung führen um weniger Aufsehen zu erregen. Die E-Mail, welche in der Vergangenheit als Bestätigung des Antrags gesendet wurde soll als Vorbild genommen werden und ist in Abbildung 14 zu sehen.

Absender: <noreply-bnds-reg@einmailzahlung200.de>
Betreff: Bundesweite Einmalzahlung

Sehr geehrte Damen und Herren,

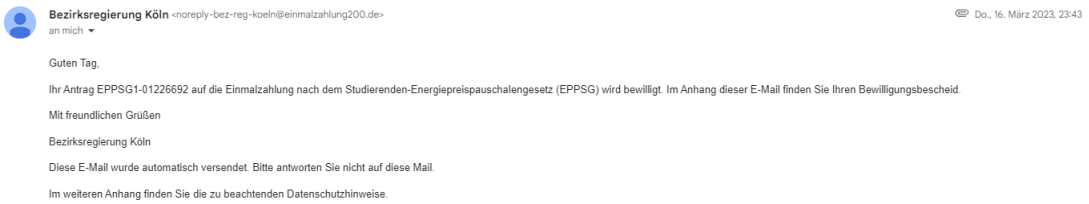
aufgrund der momentanen Finanzlage und der erneut steigenden Öl- und Gaspreise wird es eine Einmalzahlung an jede*n Bürger*inn der Bundesrepublik Deutschland geben.

Die Pauschale kann über diesen Link beantragt werden. Zur Autorisierung muss die Ausweisnummer angegeben, sowie eine Verfahren über E-Mail durchgeführt werden.

Über das genannte Verfahren wird sichergestellt, dass jede*r Bürger*inn die Ihm/Ihr zustehende Pauschale erhält.

Mit freundlichen Grüßen,
Bundesregierung Deutschland

Diese E-Mail wurde automatisch versendet. Bitte antworten Sie nicht auf diese Mail.



Bezirksregierung Köln <noreply-bez-reg-koeln@einmalzahlung200.de>
an mich

Do., 16. März 2023, 23:43

Guten Tag,

Ihr Antrag EPPSG1-01226692 auf die Einmalzahlung nach dem Studierenden-Energiepreispauschalengesetz (EPPSG) wird bewilligt. Im Anhang dieser E-Mail finden Sie Ihren Bewilligungsbescheid.

Mit freundlichen Grüßen

Bezirksregierung Köln

Diese E-Mail wurde automatisch versendet. Bitte antworten Sie nicht auf diese Mail.

Im weiteren Anhang finden Sie die zu beachtenden Datenschutzhinweise.

Abbildung 14: Vorlage der Phishing-E-Mail

3.5 E-Mailsignaturen

Das Signieren von E-Mails ist sehr hilfreich, wenn es darum geht eine E-Mail auf Authentizität zu prüfen. Wenn E-Mails nur von Mitarbeitern in einer Firma Signiert werden sollen, kann die Firma eine eigene Zertifizierungsstelle erstellen und nur für Mitarbeiten Schlüsselpaare ausstellen lassen. So können Mitarbeiter untereinander E-Mails austauschen, die nur von Mitarbeitern signiert werden können.

Es könnte einen Server geben, auf dem die öffentlichen Schlüssel aller Mitarbeiter liegen. Zudem muss jeder Mitarbeiter seinen eigenen privaten Schlüssen haben. Die Schlüsselpaare können Beispielsweise von einem Administrator erzeugt werden und am ersten Arbeitstag per USB-Stick oder ähnlichen Medien übergeben werden.

Wenn ein Mitarbeiter nun eine E-Mail senden möchte, kann diese mit dem privaten Schlüssel signiert und die Signatur mit dem öffentlichen Schlüssel überprüft werden. So kann sichergestellt werden, dass eine Nachricht auch wirklich vom Chef der Firma stammt und die E-Mail-Adresse nicht gespooft wurde.

Um ein solches Signaturverfahren in einem kleinen Rahmen auszuprobieren, kann eine selbst geschriebene E-Mail signiert und an sich selbst zurück geschickt werden. Um dies in *Claws-Mail* zu erreichen müssen zuerst zwei weitere Plugins aktiviert werden.

Die Namen der Plugins sind *PGP/Core* und *PGP/MIME*. PGP steht für *Pretty Good Privacy* und ist ein Programm um Daten zu verschlüsseln und zu signieren. Sobald die Plugins aktiviert sind, kann ein eigenes Schlüsselpaar erzeugt werden. Um ein Schlüsselpaar zu generieren gibt es eine Funktion unter dem Menüpunkt *Accountpreferenzen* unter *Plugins PGP*. Die resultierende Ausgabe kann in Abbildung 15 gesehen werden. Als letzter Schritt der Vorbereitung muss das Signieren von E-Mails aktiviert werden. Die Option dafür findet sich in dem Menüpunkt *Privacy*.

Nun kann eine E-Mail an sich selbst gesendet werden. Wie in Abbildung 16 zu sehen ist, wird die Signatur als gültig angezeigt. Dies liegt daran, dass die E-Mail mit dem eben erstellten privaten Schlüssel signiert und dem dazugehörenden öffentlichen Schlüssel überprüft wurde. Da beide Schlüssel zusammengehören ist die E-Mail als gültig gekennzeichnet.

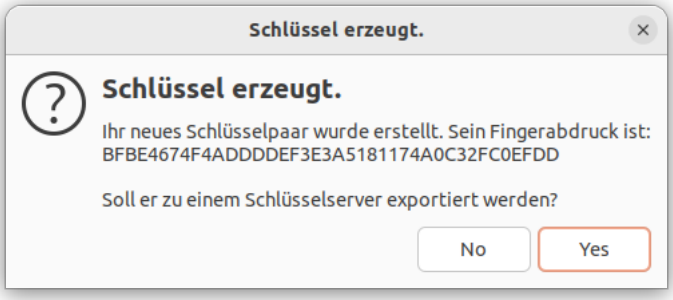


Abbildung 15: Ausgabe des erzeugten Schlüsselpaares

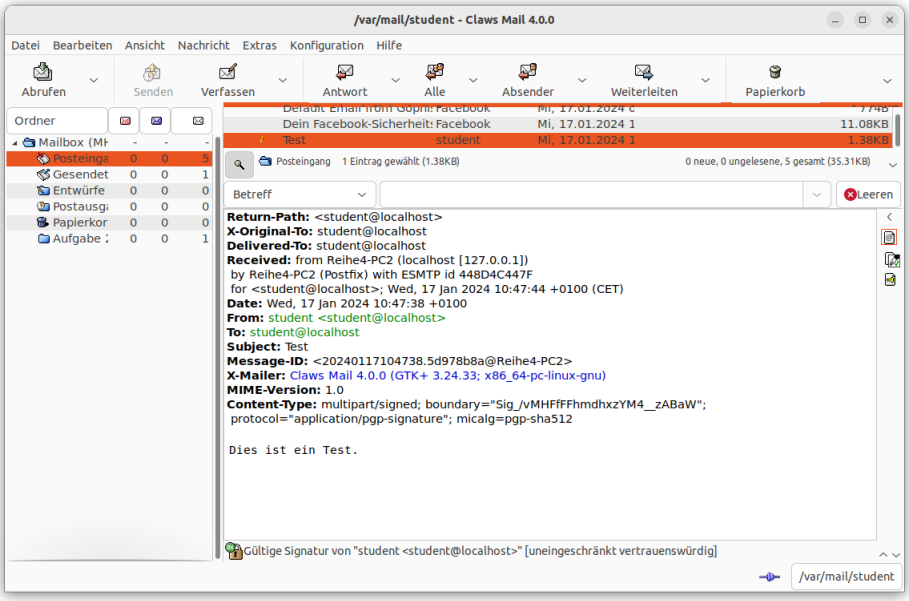


Abbildung 16: E-Mail mit gültiger Signatur

3.6 Anti-Phishing Training

Sehr geehrte Damen und Herren,

dem Auftrag von Ihnen folgend haben wir ein zweiteiliges Programm zur Verbesserung der Phishing-Problematik erstellt. Da verschiedenste Problemstellen entdeckt wurden, folgen Hinweise zur Verbesserung der Infrasturktur. Ebenso folgt ein Outlining für ein Training, das Ihren Mitarbeitern dabei Helfen soll, Phishing-E-Mails frühzeitig zu erkennen und so den Schaden durch Phishing zu minimieren.

Es existieren verschiedenste Technologien um Phishing-E-Mails automatisch zu filtern. Der einfachste Weg zu diesem Ziel ist einen Spam-Filter in jedem E-Mail-Client zu installieren. Spam-Filter haben verschiedene Techniken um nicht authentische E-Mails automatisch in einen extra dafür angelegten Ordner im E-Mail-Client zu verschieben oder direkt zu löschen. So wird der Kontakt zwischen Mitarbeitern und potentiellen Phishing-E-Mails ohne großen Aufwand minimiert. Eine Technologie die sehr gut dazu geeignet ist, um E-Mails als authentisch zu identifizieren ist DMARC. DMARC steht für Domain-based Message Authentication Reporting Conformance und baut auf den Protokollen SPF und DKIM auf. SPF sthet für *Sender Policy Framework* und verfolgt die Absicht das Spoofen von E-Mail-Adressen zu verhindern. Dies geschiet dadruch, dass ein Domainadministrator eine Reihe E-Mail-Server veröffentlicht, die autorisiert sind, E-Mails mit der Domain zu versenden. Wenn der Empfänger nun prüft, ob die Return-Adresse eine autorisierte IP-Adresse ist, kann das Nachahmen von E-Mails-Adressen oft direkt erkannt werden. DKIM sorgen dafür, das E-Mails digital signiert werden um den Sender der E-Mail eindeutig zu bestimmen. Dazu wird ein Schlüsselpaar aus einem privaten und einem öffentlichen Schlüssel genutzt. So kann nur die Person die den privaten Schlüssel hat eine E-Mail signieren. Der öffentliche Schlüssel sollte jedem anderen zugänglich sein, da mit diesem die Signatur überprüft werden kann. Auch kann eine Signatur für eine bestimmte Domäne ausgestellt werden. So kann eine E-Mail die von Ihrem E-Mail-Server gesendet wird eindeutig zugeordnet werden und das spoofen Ihrer E-Mail-Adressen eingeschränkt bis ganz verhindert werden.

Da nicht alle Phishing-E-Mails herausgefilter werden können, sollte auch nach der Anwendung der Anti-Phishing-Technologien ein Training der Mitarbeiter stattfinden. Ein Training besteht im normal Fall aus drei Phasen: Awareness, Eucation und Training.

In der erste Phase, Awareness, soll den Mitarbeitern klar gemacht werden, dass eine Gefahr durch Phishing-Angriffe besteht. Die Gefahr bezieht sich hierbei nicht nur auf die Firma und Firmendaten, sonder auch auf persönliche Informationen wie Passwörter, Nutzernamen für verschiedene Webseiten oder das Herunterladen und Installieren von Malware die Daten auf dem Computer vernichten kann. Wichtig ist jedoch, dass die Mitarbeiter durch den Vortrag oder die Informationen kein Gefühl der Machtlosigkeit bekommen. Wenn es zu radikal dargestellt wird, können Mitarbeiter die Motivation verlieren überhaupt Versuchungen anzustellen um Phishing zu vermeiden.

In der zweiten Phase, Education, soll beigebracht werden, wie Phishing zu erkennen ist. Hierbei ist wichtig, dass es kein schlichtes Auswendignlernen von möglichen Angriffsvektoren ist, sondern, im besten Fall, spielerisch gezeigt wird, wie Phishing-E-Mails erkannt werden können. Auch sollte dies in eine bezahlten Arbeitsumgebung stattfinden, damit weitere positive Aspekte vermittelt werden und die Motivatoin hoch bleibt. Wichtige Punkte die während dieser Phase zu erwähnen sind, sind die Arten wie vorallem E-Mail-Adressen und Internetadressen wie bekannte Adressen aussehen und doch einem Angreifer gehören können. Dies wird oft durch sogennantes spoofing oder Homographen realisiert. Spoofing bedeutet, dass vorallem Absendeadressen bei E-Mails, genau so aussehen wie eine bekannte Adresse, die E-Mail jedoch von jemand anderem gesendet wurde. Eine weitere Möglichkeit Internetadressen bekannt aussehen zu lassen sind Homographen oder Homoglyphen. Homographen sind ähnlich aussehende Buchstaben im lateinischen Alphabet. So kann ein großes i "I" in Internetadressen oft nur schwer von einem kleinen L "l" unterschieden werden. Homogly-

phen sind Schirftzeichen aus anderen Schriftsystemen wie Kyrillisch, die aussehen wie lateinische Buchstaben. Beide dieser Methoden kann dazu führen, dass eine bekannte Internetadresse wie *www.facebook.de* nicht von der gefälschten Adresse *www.facebcok.de* unterschieden werden kann. Es ist auch wichtig zu bedenken, dass keine unerwünschten Aktionen zu einer Belohnung führen. Wenn eine E-Mail als Phishing erkannt werden soll ist es nicht förderlich, wenn die Antwort, ob die E-Mail gefälscht oder authentisch war, hinter einem Link in der E-Mail gegeben wird. So wird das klicken auf den Link, mit der Belohnung zu wissen ob es sich um eine Phishing-Mail handelt, ermutigt.

In der letzten Phase, Training, soll das zuvor erlernte angewendet werden. Es muss jedoch beachtet werden, dass eine dafür erstellte test Phishing-Kampagne nicht unbedingt positive Auswirkungen hat. Durch eine falsche Kampagne kann das Vertrauen der Mitarbeiter in die Firma stark leiden was nicht wünschenswert ist. Ein Vertrauensbasis ist für ein gesundes Firma-Mitarbeiter-Verhältnis wichtig. Trotzdem sollte es Möglichkeiten für die Mitarbeitern geben, das gelernte regelmäßig anzuwenden, jedoch in einem kontrollierten Rahmen.

4 Zusammenfassung und Fazit

In diesem Versuch wurden viele Aspekte des Phishing untersucht. Es wurden E-Mails auf ihre Authentizität überprüft und eigene Phishing-E-Mails geschrieben. Durch das Tool *GoPhish* wurde eine authentische E-Mail von facebook nach gebaut und so manipuliert, dass die Nutzerdaten die in Loginfelder eingegeben werden an uns geschickt werden. In *GoPhish* konnte daraufhin gesehen werden, ob die E-Mail empfange, geöffnet und die Daten gesendet wurden. So verfasste Phishing-E-Mails haben das Potential Nutzerdaten von hunderten Menschen zu sammeln. Damit weniger Menschen auf Phishing hereinfallen wurden verschiedene Ansätze verfolgt um über Phishing aufzuklären. Zum einen sollte eine E-Mail mit eigenem Ziel, Senderadresse und Inhalt erstellt werden. Dies versetzte uns in die gleiche Lage, wie auch echte Angreifer sich befinden. Auch wurde ein Trainingsprogramm entworfen, dass über Phishing aufklären soll.

Der Versuchr war sehr aufschlussreich und hat einen guten Einblick in Phishing gegeben. Die Taktiken die beim Phishing eingesetzt werden waren uns vorher nicht genau bekannt. Jetzt können wir auf viel mehr Details achten, die Phishing-E-Mails enttarnen können. Die Aufgaben waren gut formuliert und leicht verständlich. Das erstellen der E-Mail-Kampagne mit *GoPhish* war sehr Interessant und hat gezeigt, wie einfach es ist, potentiell tausende Menschen mit falschen E-Mails zu erreichen um Nutzerdaten zu klauen. Der Versuch war ein guter Abschluss für das Grundlagenpraktikum.

5 LLM

In diesem Versuch wurden keine Large-Language Models(LLM) verwendet. Die Texte sind alleine die Arbeit der Mitglieder der Gruppe 43 wie zubeginn angegeben.

Literatur

[1] Bayesscher spamfilter. URL https://de.wikipedia.org/wiki/Bayesscher_Spamfilter.

[2] Ruhr-Universität Bochum Lehrstuhl für Netz-und Datensicherheit. Bachelor Grundlagenpraktikum ITS: Veranstaltungsseite der Fakultät für Elektrotechnik und Informationstechnik. URL https://informatik.rub.de/studium/lehrveranstaltungen/.

[3] Ruhr-Universität Bochum Lehrstuhl für Netz-und Datensicherheit. Aufgabenstellung zum Praktikumsversuch. Bochum, 2023.